



Corporación Unificada Nacional de Educación Superior — CUN

Programa de Ingeniería de Sistemas

**COTEJO: PROGRAMA DE AUDITORÍA DE SISTEMAS CON VERIFICACIÓN
AUTOMATIZADA DE CONTROLES Y PAPELES DE TRABAJO REPRODUCIBLES**

ENTREGA 1 · IDEA DE PROYECTO

Presentado por:

Sergio Alejandro Montoya Granados

sergio.montoya@cun.edu.co

Nicolás Torres Perdomo

nicolas.perdomot@cun.edu.co

Oscar Julián Rincón Bejarano

oscar.rinconbbe@cun.edu.co

Auditoría de Sistemas ISD39 · Grupo 30112 · Periodo 2026B

Bogotá, D. C., Colombia · Septiembre de 2026



Programa de Ingeniería de Sistemas

**COTEJO: PROGRAMA DE AUDITORÍA DE SISTEMAS CON VERIFICACIÓN
AUTOMATIZADA DE CONTROLES Y PAPELES DE TRABAJO REPRODUCIBLES**

Documento académico de proyecto

Presentado a:

DANIEL ALEJANDRO GARCIA RODRIGUEZ

Asignatura: Auditoría de Sistemas

Versión: 0.1

Fecha de entrega: 1 de septiembre de 2026

Corporación Unificada Nacional de Educación Superior — CUN

Bogotá, D. C., Colombia

Control del documento

La Tabla 1 identifica el proyecto, el equipo y la versión de este documento.

Tabla 1

Identificación del proyecto y del equipo de trabajo

Campo	Información
Título del proyecto	Cotejo: programa de auditoría de sistemas con verificación automatizada de controles y papeles de trabajo reproducibles
Asignatura y grupo	Auditoría de Sistemas IDS39 · Grupo 30112· Periodo 2026B
Integrantes	Sergio Alejandro Montoya Granados — sergio.montoya@cun.edu.co Nicolás Torres Perdomo — nicolas.perdomot@cun.edu.co Oscar Julián Rincón Bejarano — oscar.rinconbbe@cun.edu.co
Docente	DANIEL ALEJANDRO GARCIA RODRIGUEZ
Sistema auditado	Rastro, aplicación de rastreo de envíos desplegada en Amazon Web Services por el mismo equipo
Versión	0.1
Repositorio o carpeta de evidencias	Se habilitará al inicio de la fase 3 del plan de trabajo. Los papeles de trabajo y la secuencia de ejecución se versionarán allí.
Fecha de corte	1 de septiembre de 2026

Tabla de contenido

Control del documento.....	3
Tabla de contenido.....	4
1. Resumen de la idea y palabras clave.....	6
2. Introducción	6
3. Contextualización y entornos del proyecto.....	7
3.1 Entorno organizacional y de usuarios	7
3.2 Entorno tecnológico	8
3.3 Entorno social, ético, legal y ambiental	10
3.4 Síntesis de oportunidades y restricciones	11
4. Antecedentes y estado de la situación.....	12
5. Planteamiento del problema.....	14
5.1 Descripción y delimitación	14
5.2 Causas, efectos y evidencia.....	15
5.3 Pregunta de proyecto.....	16
6. Justificación	16
7. Objetivos	17
7.1 Objetivo general.....	17
7.2 Objetivos específicos	18
8. Alcance, exclusiones, restricciones y supuestos	18

9. Propuesta inicial de solución de Ingeniería de Sistemas	20
9.1 Idea central y propuesta de valor	20
9.2 Alternativas consideradas y criterio de selección	21
9.3 Arquitectura o modelo de solución inicial	22
10. Requisitos preliminares y criterios de aceptación.....	26
11. Metodología y plan inicial de trabajo	27
12. Viabilidad preliminar	29
12.1 Viabilidad técnica	29
12.2 Viabilidad operativa.....	29
12.3 Viabilidad económica y temporal	30
12.4 Viabilidad legal, ética y de seguridad	30
13. Riesgos iniciales.....	31
14. Resultados, entregables e indicadores esperados.....	32
Referencias.....	34
Anexo. Matriz de retroalimentación docente.....	36

1. Resumen de la idea y palabras clave

Las organizaciones que despliegan sistemas en la nube declaran controles de seguridad en sus documentos de diseño, pero rara vez disponen de un mecanismo que compruebe que esos controles están efectivamente configurados y que funcionan. Cuando la verificación existe, se realiza de forma manual, se documenta con capturas de pantalla sin trazabilidad y describe un único instante. El proyecto propone Cotejo, un programa de auditoría de sistemas que ejecuta de forma automatizada un catálogo de pruebas sobre una aplicación desplegada en Amazon Web Services y produce papeles de trabajo reproducibles. El sistema auditado es Rastro, una aplicación de rastreo de envíos construida por el mismo equipo, lo que asegura un objeto real y acceso completo a su configuración. Cotejo ejecuta tres clases de prueba: de cumplimiento sobre la configuración de la infraestructura, sustantivas sobre el comportamiento efectivo de los controles de acceso de la aplicación, y de integridad sobre la bitácora de auditoría mediante el recálculo de su cadena de funciones hash. Cada prueba conserva el comando ejecutado, su salida literal, la marca de tiempo y una huella criptográfica del archivo de evidencia, de modo que un tercero pueda repetir la verificación y obtener el mismo resultado. Cada control se traza a un marco de referencia reconocido. El resultado esperado es un informe de hallazgos sustentado en evidencia recuperable y no en afirmaciones.

Palabras clave: auditoría de sistemas, auditoría continua, papeles de trabajo, pruebas de cumplimiento, computación en la nube.

2. Introducción

La adopción de servicios gestionados en la nube desplazó buena parte del control técnico hacia la configuración. Hoy, que un dato esté cifrado, que un contenedor no sea público o que la actividad

quede registrada depende de un conjunto de parámetros que se establecen una vez y que casi nadie vuelve a mirar. El riesgo que introduce ese modelo no es la ausencia de controles, sino la distancia entre el control que se documenta y el control que efectivamente opera. Un diagrama de arquitectura puede afirmar que el acceso está restringido por rol sin que nadie haya comprobado qué ocurre cuando un usuario del rol equivocado invoca la operación.

Para la Ingeniería de Sistemas, cerrar esa distancia es un problema de diseño y no de redacción: exige definir qué se va a verificar, traducir cada control a una prueba ejecutable, conservar la evidencia de manera que otro pueda repetirla y trazar cada hallazgo hasta el comando que lo produjo. Este documento corresponde a la fase de idea del proyecto Cotejo. No presenta un programa construido, sino la definición del problema, el análisis de los entornos que lo condicionan, la comparación de alternativas de verificación, la arquitectura preliminar del programa, los requisitos con sus criterios de aceptación y la evaluación de viabilidad. Los apartados 1 a 6 ubican y sustentan el problema; del 7 al 10 definen qué se hará y bajo qué condiciones se aceptará; del 11 al 14 establecen el método, la viabilidad, los riesgos y los indicadores.

3. Contextualización y entornos del proyecto

El análisis de entornos delimita qué puede auditarse, con qué medios y bajo qué obligaciones profesionales. Cierra con una síntesis que traduce cada hallazgo en un efecto sobre el alcance.

3.1 Entorno organizacional y de usuarios

El objeto de auditoría es Rastro, una aplicación de rastreo de envíos desplegada en una cuenta de AWS Academy Learner Lab y construida por los mismos integrantes en el marco de otra asignatura. Esa condición tiene una ventaja y un costo. La ventaja es que el equipo dispone de

acceso completo a la configuración, al código y a los registros, de modo que la auditoría opera sobre un sistema real y no sobre un supuesto. El costo es una amenaza a la independencia que se declara y se atiende en el apartado 3.3.

El proceso auditado abarca el despliegue y la operación de Rastro: la configuración de los servicios de datos, cifrado y registro de actividad; la autorización de las operaciones de la aplicación; el aislamiento de los datos entre organizaciones; y la conservación de la bitácora de auditoría. Quedan fuera el proceso de desarrollo y la gestión del proyecto.

La Tabla 2 relaciona cada actor con su papel en la auditoría y su necesidad observable.

Tabla 2

Mapa de actores del proceso de auditoría

Actor	Papel en la auditoría	Necesidad observable	Relación con el programa
Auditor	Define el universo auditable, ejecuta el programa de pruebas y emite los hallazgos.	Obtener evidencia que sostenga una conclusión sin depender de la palabra del auditado.	Usuario principal; ejecuta el programa y consulta los papeles de trabajo.
Responsable técnico del sistema auditado	Construyó y opera el componente evaluado; recibe los hallazgos y define la corrección.	Entender qué falló, con qué evidencia y qué debe cambiar.	Destinatario del informe; no tiene permiso para modificar los papeles de trabajo.
Responsable del proyecto	Decide sobre la aceptación o corrección de cada hallazgo según su severidad.	Priorizar correcciones con criterio de riesgo.	Destinatario del informe consolidado.
Evaluable independiente	Reejecuta el programa para comprobar que el resultado reportado se reproduce.	Verificar la auditoría sin repetir el trabajo manualmente.	Ejecuta el mismo programa y coteja las huellas criptográficas de la evidencia.

Nota. El responsable técnico es el auditado y no un usuario del programa. La distinción es relevante porque de ella depende la separación de funciones descrita en el apartado 11.

3.2 Entorno tecnológico

El sistema auditado y el programa de auditoría residen en la misma cuenta de AWS Academy Learner Lab, número 484948252891, en la región us-east-1. El entorno impone tres condiciones

relevantes para una auditoría: las credenciales caducan cada cuatro horas, el presupuesto es de 50 dólares por cuenta, y no están disponibles los servicios gestionados de evaluación continua de configuración que un auditor usaría en un entorno productivo. Esa última ausencia es precisamente lo que obliga a construir el programa y lo que convierte al proyecto en un ejercicio de ingeniería y no en la operación de una herramienta comercial.

La Tabla 3 inventaría las capacidades disponibles para auditar y las que no lo están.

Tabla 3

Capacidades del entorno para el ejercicio de auditoría

Capacidad	Disponibilidad	Uso previsto o consecuencia
Consulta de identidad de sesión (STS)	Disponible	Registrar bajo qué identidad se ejecutó cada prueba, dato que forma parte del papel de trabajo.
Lectura de IAM (list-roles, get-role)	Disponible	Inventariar los permisos del rol de ejecución para evaluar el principio de mínimo privilegio.
CloudTrail	Disponible	Verificar que el registro de actividad esté activo y con validación de integridad, y contrastar los cambios de configuración.
S3, KMS, DynamoDB, Cognito	Disponibles	Consultar el estado de los controles de cifrado, versionado, acceso público y grupos de usuarios.
Lambda y API Gateway	Disponibles	Ejecutar el programa de pruebas e invocar la interfaz del sistema auditado con usuarios de prueba.
Servicios gestionados de evaluación de configuración y de postura de seguridad	No disponibles	No pueden emplearse. El programa debe construir sus propias pruebas de cumplimiento consultando directamente la interfaz de programación de cada servicio.
Servicio gestionado de gestión de auditorías y evidencias	No disponible	El almacén de papeles de trabajo y el cálculo de huellas criptográficas se implementan como parte del proyecto.

Nota. El estado de cada capacidad corresponde a la configuración del laboratorio en la fecha de corte y fue verificado mediante la interfaz de línea de comandos de AWS.

Antes de definir el programa, el equipo ejecutó una prueba preliminar cuyo resultado es la evidencia central del problema descrito en el apartado 5.1. Se configuró deliberadamente un punto de acceso público sobre una función, con una política de recurso que autoriza de forma explícita a cualquier principal, y luego se comprobó su comportamiento real.

La Tabla 4 registra la prueba preliminar que sustenta el planteamiento del problema.

Tabla 4

Prueba preliminar: configuración declarada frente a comportamiento efectivo

Elemento	Procedimiento	Resultado observado
Configuración declarada	Consulta de la política de recurso mediante <code>aws lambda get-policy</code> .	La política autoriza la acción de invocación al principal * sin condición restrictiva adicional. Leída de forma aislada, describe un recurso de acceso libre.
Comportamiento efectivo	Petición HTTP al punto de acceso, tras esperar la propagación de la política.	Respuesta 403. El acceso está impedido por un control situado por encima de la configuración del recurso.
Conclusión de la prueba	Contraste entre ambas observaciones.	La configuración declarada no describe el comportamiento efectivo. Un procedimiento de auditoría basado solo en leer configuraciones habría reportado un hallazgo inexistente.

Nota. Ambas observaciones son recuperables: el comando y la petición pueden repetirse sobre la misma cuenta y producen el mismo resultado. Las salidas literales, con su marca de tiempo, se conservan en la carpeta de evidencias del proyecto.

3.3 Entorno social, ético, legal y ambiental

La condición ética dominante del proyecto es la independencia. El equipo audita un sistema que él mismo construyó, lo que constituye una amenaza de autorrevisión: quien evalúa un control tiende a confirmar la decisión que tomó al diseñarlo. El código de ética profesional para auditores de sistemas exige objetividad y la revelación de cualquier circunstancia que pueda comprometerla (ISACA, s. f.). El equipo adopta tres medidas y declara la limitación en lugar de omitirla. La primera es la rotación interna: ningún integrante ejecuta ni evalúa las pruebas del componente que construyó. La segunda es que el programa es determinista, de modo que su resultado no depende del criterio de quien lo ejecuta. La tercera es que un evaluador externo puede reejecutarlo y contrastar las huellas criptográficas de la evidencia. Aun con esas medidas, la auditoría no alcanza el grado de independencia de una revisión externa, y el informe lo hará constar.

En lo legal, los papeles de trabajo pueden contener fragmentos de los datos del sistema auditado. Como Rastro opera exclusivamente con datos sintéticos, la evidencia no incorpora información personal y el proyecto no genera obligaciones de tratamiento bajo la Ley 1581 de 2012. Si el programa se aplicara a un sistema en producción, la evidencia sí quedaría cubierta por esa norma y exigiría minimización y acceso restringido; el diseño ya contempla el acceso restringido al almacén de papeles de trabajo. En lo social, un informe de auditoría enumera debilidades explotables, por lo que su circulación se limita a los destinatarios definidos en el apartado 3.1. Un principio adicional gobierna todo el ejercicio: no se reporta ningún hallazgo sin la evidencia que lo sustente, y no se completa una prueba que no haya podido ejecutarse. En el plano ambiental, el consumo del programa es marginal frente al del sistema auditado y no se cuantifica, porque el equipo no dispone de instrumentos de medición.

3.4 Síntesis de oportunidades y restricciones

La Tabla 5 traduce el análisis de entornos en decisiones de proyecto.

Tabla 5

Traducción del análisis de entornos en decisiones de proyecto

ID	Tipo	Enunciado	Prioridad	Efecto sobre el alcance
OP-01	Oportunidad	El equipo tiene acceso total a la configuración y al código del sistema auditado.	Alta	Permite construir pruebas de caja blanca y verificar controles que un auditor externo no alcanzaría.
OP-02	Oportunidad	Toda la configuración de la nube es consultable por interfaz de programación.	Alta	Hace posible automatizar las pruebas de cumplimiento y repetirlas sin intervención manual.
OP-03	Oportunidad	CloudTrail conserva un registro independiente de los cambios de configuración.	Media	Permite contrastar si un control fue modificado entre dos ejecuciones del programa.

ID	Tipo	Enunciado	Prioridad	Efecto sobre el alcance
RE-01	Restricción	El equipo audita su propio sistema.	Alta	Se declara la amenaza de autorrevisión y se aplica rotación interna; no se afirma independencia plena.
RE-02	Restricción	No hay servicios gestionados de evaluación de configuración ni de gestión de evidencias.	Alta	Las pruebas y el almacén de papeles de trabajo se construyen como parte del proyecto.
RE-03	Restricción	Las credenciales caducan cada cuatro horas y el presupuesto es de 50 dólares.	Media	El programa debe ejecutarse por demanda y no de forma continua; se excluye la vigilancia permanente.
RE-04	Restricción	El sistema auditado se construye en paralelo durante el mismo periodo.	Alta	El programa solo puede probar controles ya implementados; las fases se sincronizan con el avance de Rastro.
SU-01	Supuesto por validar	Rastro expondrá los controles de autorización y la bitácora a tiempo para ser auditados.	Alta	Si se retrasa, las pruebas sustantivas se ejecutan sobre un subconjunto y se documenta la limitación de alcance.
DE-01	Dependencia crítica	Disponibilidad de la cuenta del laboratorio durante todo el periodo.	Alta	Su pérdida obliga a reejecutar el programa completo en la cuenta de reemplazo.

4. Antecedentes y estado de la situación

La verificación automatizada de controles no es una idea nueva. Vasarhelyi y Halper (1991) describieron la auditoría continua de sistemas en línea como el desplazamiento de la revisión periódica hacia la comprobación permanente y automatizada, ejecutada sobre el propio sistema y no sobre reportes derivados de él. Dos décadas después, Chan y Vasarhelyi (2011) revisaron la adopción práctica de ese enfoque y señalaron que su obstáculo no era técnico sino organizativo: exige definir con precisión qué constituye una excepción y qué evidencia la sustenta, tarea que las auditorías tradicionales resolvían con criterio profesional caso por caso. Ese es exactamente el trabajo que el presente proyecto formaliza en su matriz de controles.

Del lado normativo, existen marcos consolidados que definen qué debe controlarse y cómo documentarlo. COBIT 2019 establece objetivos de gestión sobre servicios de seguridad y sobre controles de procesos de negocio (ISACA, 2018); ITAF fija las normas de desempeño y de comunicación aplicables a un trabajo de aseguramiento, incluida la exigencia de evidencia suficiente y confiable (ISACA, 2020); ISO/IEC 27001 define los requisitos de un sistema de gestión de seguridad de la información (International Organization for Standardization, 2022); y el conjunto de recomendaciones del Center for Internet Security (s. f.) traduce esos principios a configuraciones concretas de una cuenta de nube. Sobre el registro de actividad, Kent y Souppaya (2006) fijan qué debe conservar una entrada de auditoría, y Schneier y Kelsey (1999) demostraron cómo encadenar registros para que una alteración posterior resulte detectable, técnica que este proyecto emplea como prueba de integridad.

La Tabla 6 compara los enfoques de verificación existentes frente a los criterios que interesan al problema.

Tabla 6

Comparación de enfoques de verificación de controles

Enfoque	Cobertura de la infraestructura	Cobertura del comportamiento de la aplicación	Reproducibilidad de la evidencia	Disponibilidad en el entorno
Revisión manual con capturas de pantalla	Parcial y puntual.	Posible, pero dependiente del criterio de quien la ejecuta.	Baja: la captura no conserva el comando ni permite repetir la prueba.	Disponible; es la práctica habitual.
Lista de verificación documental	Nula: verifica lo declarado, no lo configurado.	Nula.	Media: el documento es estable, pero no acredita el estado del sistema.	Disponible.
Servicios gestionados de evaluación de configuración	Alta y continua.	Nula: no ejercitan la lógica de	Alta dentro de la plataforma del proveedor.	No disponible en el entorno del proyecto.

Enfoque	Cobertura de la infraestructura	Cobertura del comportamiento de la aplicación	Reproducibilidad de la evidencia	Disponibilidad en el entorno
		autorización de la aplicación.		
Programa propio de verificación automatizada	Alta, limitada a los controles que se programen.	Alta: puede invocar la aplicación con usuarios de prueba por rol.	Alta: conserva comando, salida, fecha y huella criptográfica.	Disponible; requiere construirlo.

Nota. La comparación se construyó sobre enfoques y no sobre productos específicos, con el fin de no atribuir características concretas a proveedores sin verificación directa.

El vacío se lee en las dos columnas centrales. Los servicios gestionados evalúan la configuración de la infraestructura con solvencia, pero no ejercitan la lógica de la aplicación: no pueden saber si un usuario del rol conductor logra crear un envío ni si un usuario de una organización alcanza los datos de otra, porque esas reglas viven en el código. Las revisiones manuales sí llegan hasta allí, pero producen evidencia que nadie puede repetir. Ninguno de los enfoques disponibles cubre simultáneamente el comportamiento efectivo de los controles de la aplicación y la reproducibilidad de la evidencia, y ese cruce es el que ocupa este proyecto.

5. Planteamiento del problema

5.1 Descripción y delimitación

Un control declarado no es un control verificado. En un sistema desplegado en la nube, la afirmación de que los datos están cifrados, de que el registro de actividad está activo o de que una operación está restringida por rol suele apoyarse en un documento de diseño o en la memoria de quien configuró el servicio. La situación deseada es distinta: cada control debe tener asociada una prueba ejecutable, una evidencia conservada y un resultado que un tercero pueda reproducir.

La distancia entre ambas situaciones no es hipotética y el equipo la comprobó. La prueba preliminar registrada en la Tabla 4 muestra un caso en el que la configuración declarada y el comportamiento efectivo se contradicen: la política del recurso autoriza de forma explícita a

cualquier principal, y sin embargo toda invocación se rechaza con código 403. Un procedimiento de auditoría basado en leer configuraciones habría concluido que existía un punto de acceso abierto, que es un hallazgo falso; un procedimiento basado en ejercitar el sistema concluye lo contrario. La observación es recuperable: el comando y la petición pueden repetirse y producen el mismo resultado.

De esa constatación se derivan tres consecuencias observables. La primera es que la evidencia habitual de auditoría, la captura de pantalla, no permite repetir la prueba ni acredita cuándo se tomó. La segunda es que la verificación describe un instante: un control puede cumplirse el día de la revisión y dejar de cumplirse al día siguiente sin que nadie lo advierta. La tercera es que, sin una correspondencia explícita entre el control y un marco de referencia, el criterio con el que se evalúa queda a discreción de quien audita.

El problema se delimita en cuatro sentidos. En lo funcional, cubre la verificación de controles de seguridad y de integridad sobre un sistema desplegado, y excluye la auditoría del proceso de desarrollo, la revisión de código y la evaluación de continuidad del negocio. En lo organizacional, se circunscribe a un único sistema auditado, Rastro, y a la cuenta de nube en la que reside. En lo técnico, se limita a los controles que puedan comprobarse mediante la interfaz de programación del proveedor o mediante la interfaz del sistema auditado. En lo temporal, al periodo académico del curso.

5.2 Causas, efectos y evidencia

El síntoma visible es que nadie sabe si un control funciona. La causa no es la falta de una herramienta, sino que la verificación no está definida como un procedimiento con criterio, prueba y evidencia.

La Tabla 7 distingue causas, efectos y la evidencia que respalda cada afirmación.

Tabla 7

Árbol del problema: causas, efectos y evidencia asociada

Nivel	Enunciado	Efecto que produce	Evidencia que lo sustenta
Causa directa 1	La verificación se realiza leyendo configuraciones y no ejercitando el sistema.	Se reportan hallazgos que no corresponden al comportamiento real, en cualquiera de los dos sentidos.	Prueba preliminar de la Tabla 4, reproducible mediante los comandos allí descritos.
Causa directa 2	La evidencia se captura como imagen, sin el comando que la produjo ni marca de tiempo verificable.	La prueba no puede repetirse ni contrastarse por un tercero.	Propiedad conocida del formato: una captura de pantalla no conserva el procedimiento que la originó.
Causa directa 3	No existe correspondencia explícita entre cada control y un marco de referencia.	El criterio de evaluación depende de quien audita y varía entre revisiones.	Los marcos citados en el apartado 4 exigen esa correspondencia (ISACA, 2018, 2020).
Causa indirecta	La verificación es manual y por lo tanto costosa, de modo que se ejecuta una sola vez.	El resultado describe un instante y no el estado sostenido del control.	Chan y Vasarhelyi (2011) identifican el costo de la revisión manual como el obstáculo que motiva la auditoría continua.
Efecto 1	Un control puede dejar de operar sin que nadie lo advierta.	El sistema opera con una protección que se supone activa y no lo está.	Se deriva de las causas directas 1 y 3; su comprobación es un objetivo del proyecto.
Efecto 2	Las conclusiones de la auditoría no son verificables por un tercero.	El informe vale lo que valga la confianza en quien lo firma.	Se deriva de la causa directa 2.

Nota. La evidencia de la causa directa 1 es recuperable y fue producida por el propio equipo. Las causas 2 y 3 se sustentan en propiedades del formato de evidencia y en los requisitos de los marcos citados.

5.3 Pregunta de proyecto

¿Cómo diseñar y ejecutar un programa de auditoría que verifique de forma automatizada y reproducible los controles de un sistema desplegado en la nube, cubriendo tanto la configuración de la infraestructura como el comportamiento efectivo de los controles de la aplicación, y que produzca papeles de trabajo cuya integridad y trazabilidad puedan comprobarse por un tercero?

6. Justificación

El valor de intervenir este problema está en convertir una afirmación en una comprobación. Para el responsable del sistema, disponer de un programa que se ejecuta por demanda significa saber si un cambio rompió un control antes de que lo descubra un incidente. Para el auditor, significa sustituir el criterio no documentado por un procedimiento con criterio explícito, prueba definida y evidencia conservada. Para un tercero, significa poder reejecutar la verificación en lugar de confiar en el informe.

El aporte técnico no está en auditar, que es una práctica establecida, sino en cubrir el punto que las herramientas disponibles dejan vacío: el comportamiento efectivo de los controles que viven en el código de la aplicación. Verificar que un usuario de una organización no alcanza los datos de otra, o que la bitácora detecta su propia alteración, exige ejercitar el sistema con usuarios de prueba y recalcular estructuras criptográficas; no se resuelve consultando parámetros de configuración. Ese es el elemento diferenciador y también el que se someterá a prueba.

Para la Ingeniería de Sistemas, el proyecto integra el diseño de un catálogo de controles trazado a marcos de referencia, la construcción de un ejecutor automatizado sobre servicios gestionados, el diseño de un almacén de evidencia con garantías de integridad y la aplicación de criptografía a la verificación de registros. El costo de no actuar se expresa en controles que se suponen activos sin estarlo y en informes cuya conclusión nadie puede contrastar. Los beneficios enunciados son esperados y no medidos: el apartado 14 define los indicadores con que se comprobarán.

7. Objetivos

7.1 Objetivo general

Desarrollar un programa de auditoría de sistemas que verifique de forma automatizada y reproducible los controles de configuración, de acceso y de integridad de una aplicación

desplegada en Amazon Web Services, generando papeles de trabajo con evidencia recuperable y trazable a un marco de referencia reconocido.

7.2 Objetivos específicos

La Tabla 8 detalla cada objetivo específico con su entregable, su evidencia y su criterio de aceptación.

Tabla 8

Objetivos específicos con entregable, evidencia y criterio de aceptación

ID	Objetivo específico	Entregable	Evidencia	Criterio de aceptación
OE-1	Definir el universo auditable del sistema y la matriz de controles, trazando cada control a un marco de referencia.	Matriz de controles con su referencia normativa y su tipo de prueba.	Documento versionado en el repositorio.	Cada control tiene criterio, referencia de marco y tipo de prueba; ningún control queda sin correspondencia normativa.
OE-2	Diseñar el programa de pruebas de cumplimiento, sustantivas y de integridad con su criterio de aceptación.	Programa de auditoría con el procedimiento de cada prueba.	Documento de diseño versionado.	Cada prueba indica el procedimiento exacto, el resultado esperado y la evidencia que debe conservarse.
OE-3	Construir el ejecutor automatizado y el almacén de papeles de trabajo con verificación de integridad.	Programa desplegado y operativo sobre la cuenta del laboratorio.	Secuencia de despliegue y ejecución versionada, con su salida.	El programa ejecuta el catálogo completo sin intervención manual y cada resultado queda almacenado con comando, salida, fecha y huella criptográfica.
OE-4	Ejecutar el programa, evaluar las desviaciones y emitir el informe de hallazgos.	Informe de auditoría con hallazgos clasificados por severidad.	Papeles de trabajo referenciados desde cada hallazgo.	Cada hallazgo enuncia condición, criterio, causa y efecto, y remite al papel de trabajo que lo sustenta.

8. Alcance, exclusiones, restricciones y supuestos

El alcance se acota a un catálogo de ocho controles sobre un único sistema auditado, de modo que el programa pueda construirse, ejecutarse y documentarse dentro del periodo disponible. La elección de los controles privilegia aquellos cuya verificación exige ejercitar el sistema, porque son los que ninguna herramienta disponible cubre.

La Tabla 9 delimita los elementos incluidos, excluidos y condicionados.

Tabla 9

Alcance del proyecto: elementos incluidos, excluidos y condicionados

Condición	Elemento	Justificación
Incluido	Matriz de ocho controles con su criterio y su referencia a un marco reconocido.	Es el instrumento que fija el criterio de evaluación y evita que dependa de quien audita.
Incluido	Pruebas de cumplimiento sobre la configuración de registro de actividad, cifrado, versionado y acceso público.	Son los controles de infraestructura cuya desviación tiene mayor impacto.
Incluido	Pruebas sustantivas sobre autorización por rol, aislamiento entre organizaciones y validez de las transiciones de estado.	Es la cobertura que ninguna herramienta disponible ofrece y el diferenciador del proyecto.
Incluido	Prueba de integridad de la bitácora mediante recálculo de la cadena de funciones hash y alteración controlada.	Comprueba que el mecanismo de no repudio del sistema auditado funciona.
Incluido	Almacén de papeles de trabajo con comando, salida literal, marca de tiempo y huella criptográfica del archivo.	Es la condición que hace reproducible la evidencia.
Incluido	Informe de hallazgos con condición, criterio, causa, efecto, severidad y recomendación.	Es el producto que la práctica profesional exige de un trabajo de auditoría.
Excluido	Auditoría del proceso de desarrollo, revisión de código fuente y evaluación de continuidad del negocio.	Pertenecen a otros tipos de trabajo de aseguramiento y exceden el tiempo disponible.
Excluido	Pruebas de intrusión y explotación de vulnerabilidades.	Requieren autorización específica y competencias distintas de las de este trabajo.
Excluido	Vigilancia continua y desatendida de los controles.	El entorno detiene la sesión cada cuatro horas; el programa se ejecuta por demanda.
Excluido	Auditoría de sistemas distintos de Rastro.	El objeto de auditoría se limita a un sistema para que la profundidad prime sobre la extensión.
Condicionado	Almacenamiento de los papeles de trabajo con retención inmutable.	Sujeto a que el entorno permita habilitar esa opción en el contenedor. Si no la permite, se

Condición	Elemento	Justificación
		usa versionado más huella criptográfica y se documenta la diferencia como limitación.
Condicionado	Ejecución programada del catálogo en un horario fijo.	Sujeto a la disponibilidad del servicio de planificación en el laboratorio. La ejecución por demanda se mantiene en todos los casos.

Las restricciones que enmarcan el proyecto son las registradas en la Tabla 5 con los identificadores RE-01 a RE-04, y los supuestos pendientes de validación son SU-01 y la dependencia DE-01 de la misma tabla.

9. Propuesta inicial de solución de Ingeniería de Sistemas

9.1 Idea central y propuesta de valor

La propuesta consiste en trasladar la verificación de controles desde la lectura de configuraciones y la captura de pantalla hacia un programa que ejercita el sistema y conserva la prueba de lo que hizo. El flujo principal es el siguiente: el auditor selecciona el catálogo de controles; el ejecutor recorre cada prueba consultando la interfaz de configuración del proveedor o invocando la aplicación con usuarios de prueba; cada resultado se almacena con el comando exacto, la salida literal, la marca de tiempo y la huella criptográfica del archivo; el programa compara el resultado obtenido con el criterio definido y clasifica cada control como conforme o desviado; y las desviaciones se elevan a hallazgos con su severidad.

La Tabla 10 traza cada causa priorizada hasta la capacidad que la atiende y el resultado observable.

Tabla 10

Relación entre problema, necesidad, capacidad y resultado

Causa priorizada	Necesidad derivada	Capacidad que la atiende	Resultado observable
La verificación lee configuraciones y no ejercita el sistema.	Comprobar el comportamiento efectivo y no solo el declarado.	Pruebas sustantivas que invocan la aplicación con usuarios de prueba por rol y organización.	Cada control de acceso tiene un resultado obtenido por ejecución y no por lectura.
La evidencia no conserva el procedimiento que la produjo.	Que la prueba pueda repetirse por un tercero.	Papel de trabajo con comando, salida literal, marca de tiempo y huella criptográfica.	Un tercero reejecuta el programa y obtiene el mismo resultado y la misma huella.
No hay correspondencia entre control y marco de referencia.	Que el criterio de evaluación sea explícito y no discrecional.	Matriz de controles con referencia normativa por cada control.	Cada hallazgo cita el criterio contra el que se evaluó.
La verificación manual es costosa y se ejecuta una sola vez.	Poder repetir la verificación completa a bajo costo.	Ejecutor automatizado que recorre el catálogo completo en una sola invocación.	El catálogo se reejecuta cuantas veces se requiera sin trabajo manual adicional.
Un control puede dejar de operar sin que nadie lo advierta.	Detectar la desviación de un control entre dos momentos.	Comparación del resultado actual contra la ejecución anterior, y contraste con el registro de cambios de la infraestructura.	Una desviación aparece señalada junto con el cambio que la produjo.

El diferenciador verificable es el segundo renglón: la capacidad de que otra persona repita la auditoría y obtenga el mismo resultado. No es una cualidad declarativa, sino una propiedad comprobable mediante el procedimiento descrito en el apartado 14.

9.2 Alternativas consideradas y criterio de selección

Se compararon tres alternativas de realización. La alternativa A es un programa propio de verificación automatizada. La alternativa B es la ejecución manual de un procedimiento documentado, con captura de evidencia por pantalla. La alternativa C es la adopción de un servicio gestionado de evaluación de configuración del proveedor. Los criterios se ponderaron según su efecto sobre la posibilidad de responder la pregunta de proyecto, y la escala va de 1 a 5, donde 5 es el mejor comportamiento frente al criterio.

La Tabla 11 compara las tres alternativas frente a los criterios ponderados.

Tabla 11

Matriz ponderada de comparación de alternativas

Criterio	Peso	A. Programa propio	B. Procedimiento manual	C. Servicio gestionado	Razón de la calificación
Cobertura del comportamiento de la aplicación	0,25	5	4	1	A y B pueden invocar la aplicación; C solo evalúa configuración de infraestructura y no ejercita la lógica de autorización.
Reproducibilidad de la evidencia	0,25	5	2	4	A conserva comando, salida y huella. B produce capturas que no permiten repetir la prueba. C es reproducible dentro de la plataforma del proveedor.
Disponibilidad en el entorno del proyecto	0,20	5	5	1	C no está habilitado en el laboratorio, lo que lo hace inviable con independencia de sus cualidades.
Costo de repetir la verificación completa	0,15	5	1	5	A y C se reejecutan sin trabajo manual; B exige repetir cada paso a mano.
Aporte al aprendizaje de la asignatura	0,15	5	3	1	A obliga a diseñar controles, pruebas y evidencia; C reduce el trabajo a interpretar el tablero de un proveedor.
Total ponderado	1,00	5,00	3,10	2,15	La alternativa A obtiene la calificación máxima en los criterios de mayor peso.

Nota. Los pesos priorizan los criterios que determinan si el proyecto puede responder su pregunta: la cobertura del comportamiento de la aplicación y la reproducibilidad de la evidencia son las dos propiedades que el apartado 4 identificó como vacío.

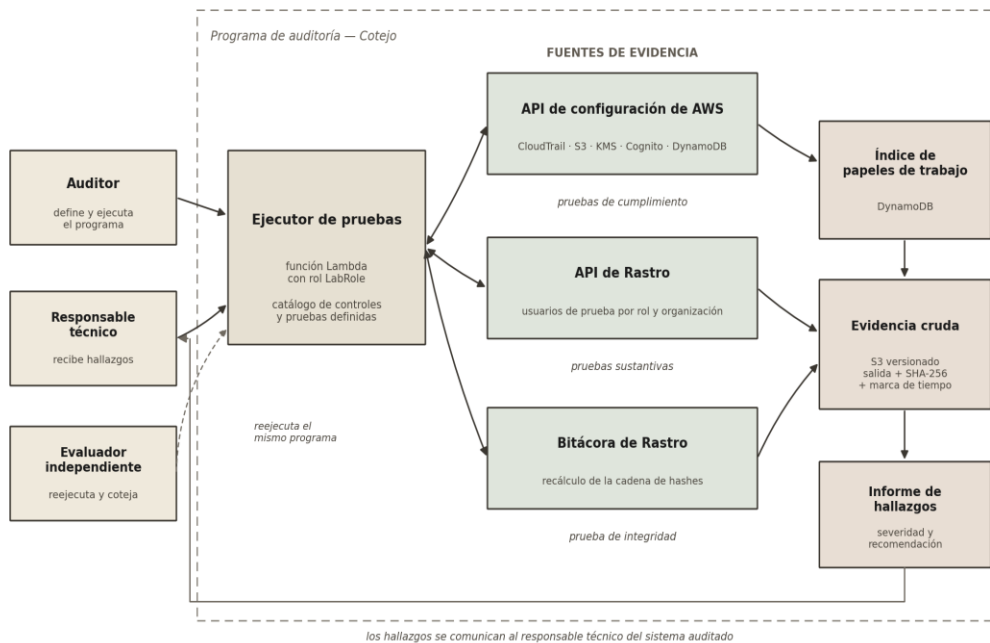
La decisión preliminar es la alternativa A. Su riesgo principal es que un programa propio solo verifica los controles que alguien programó, de modo que un control ausente del catálogo pasa inadvertido; se mitiga derivando el catálogo de marcos de referencia y no de la intuición del equipo. Su segundo riesgo es que un defecto en el propio programa produzca un falso conforme, que se atiende con la prueba de alteración controlada descrita en el apartado 14.

9.3 Arquitectura o modelo de solución inicial

La Figura 1 representa el programa como un conjunto de actores, componentes, fuentes de evidencia y productos. El ejecutor es el único componente que escribe en el almacén de papeles de trabajo de trabajo, y ningún actor lo modifica directamente.

Figura 1

Arquitectura preliminar del programa de auditoría



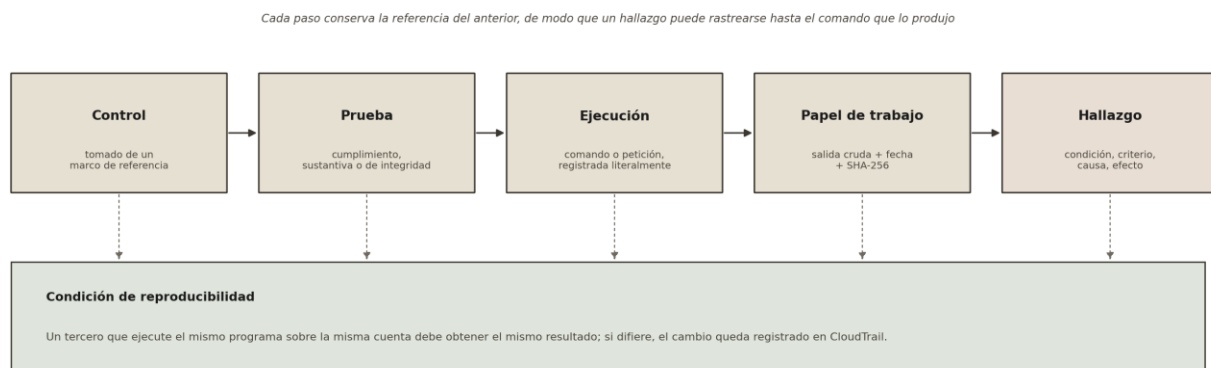
Nota. Las tres fuentes de evidencia corresponden a los tres tipos de prueba del catálogo. La línea inferior indica la comunicación de hallazgos al responsable técnico, que es el auditado y no un usuario del programa.

El ejecutor se implementa como una función que recibe el identificador del catálogo a ejecutar y recorre cada prueba en orden. Para las pruebas de cumplimiento consulta la interfaz de configuración del proveedor en modo lectura. Para las sustantivas se autentica con usuarios de prueba pertenecientes a distintos roles y organizaciones, y ejerce operaciones que deben ser rechazadas, comprobando tanto el código de respuesta como la aparición del registro correspondiente en la bitácora del sistema auditado. Para la prueba de integridad descarga la bitácora, recalcula la cadena de funciones hash y verifica que el encadenamiento cierre.

La Figura 2 detalla la trazabilidad de la evidencia. Cada paso conserva la referencia del anterior, de modo que un hallazgo del informe puede rastrearse hasta el comando que lo produjo, y a la inversa.

Figura 2

Ciclo de vida de un papel de trabajo y condición de reproducibilidad



Nota. La huella criptográfica se calcula sobre el archivo de evidencia y se almacena en el índice, de modo que una modificación posterior del archivo resulta detectable al recalcularla.

El almacén de papeles de trabajo se organiza en dos partes. Un índice en base de datos conserva, por cada ejecución y control, el identificador del control, el tipo de prueba, el criterio, el resultado obtenido, la conclusión, la identidad de sesión bajo la que se ejecutó, la marca de tiempo y la huella criptográfica del archivo de evidencia. El archivo de evidencia, con la salida literal y sin edición, se almacena en un contenedor con versionado activo. La separación entre índice y evidencia permite consultar y comparar ejecuciones sin abrir los archivos, y conservar la salida cruda sin transformarla.

La matriz de controles es el instrumento que fija el criterio de evaluación. Cada control indica contra qué marco se juzga, qué tipo de prueba lo comprueba y qué evidencia debe quedar. Su contenido preliminar se presenta a continuación.

La Tabla 12 presenta la matriz preliminar de controles con su referencia de marco, tipo de prueba y evidencia esperada.

Tabla 12

Matriz preliminar de controles del sistema auditado

ID	Control	Referencia de marco	Tipo de prueba	Evidencia esperada
C-01	El registro de actividad está activo y con validación de integridad de sus archivos.	Center for Internet Security (s. f.); Kent y Souppaya (2006)	Cumplimiento	Salida de la consulta de estado del registro, con el indicador de validación habilitado.
C-02	Las evidencias se cifran en reposo con una llave administrada por el responsable, con rotación habilitada.	ISO/IEC 27001 (International Organization for Standardization, 2022)	Cumplimiento	Estado de rotación de la llave y propiedades de cifrado de un objeto almacenado.
C-03	El contenedor de evidencias no admite acceso público.	Center for Internet Security (s. f.)	Cumplimiento	Configuración de bloqueo de acceso público del contenedor.
C-04	El contenedor de evidencias conserva versiones anteriores de cada objeto.	ISO/IEC 27001 (International Organization for Standardization, 2022)	Cumplimiento	Estado de versionado del contenedor.
C-05	Cada operación está restringida a los roles autorizados y el intento rechazado queda registrado.	ISACA (2018); OWASP Foundation (2021)	Sustantiva	Código de respuesta 403 ante un rol no autorizado y registro correspondiente en la bitácora.
C-06	Un usuario no accede a envíos, eventos ni evidencias de una organización distinta a la suya.	ISACA (2018); OWASP Foundation (2021)	Sustantiva	Respuesta de recurso inexistente ante el identificador de otra organización y registro del intento.
C-07	El sistema rechaza las transiciones de estado no contempladas en su modelo.	ISACA (2018)	Sustantiva	Código de respuesta 400 ante una transición inválida y registro correspondiente.
C-08	La bitácora permite detectar la alteración o eliminación de cualquiera de sus registros.	Schneier y Kelsey (1999)	Integridad	Punto de ruptura de la cadena señalado por el verificador tras una alteración controlada.

Nota. El catálogo se deriva de los marcos citados y no de la apreciación del equipo, de modo que un control ausente pueda atribuirse a una decisión de alcance y no a un olvido. La evaluación del principio de mínimo privilegio sobre el rol de ejecución compartido no se automatiza, porque el entorno impide corregir la desviación; se documenta como hallazgo permanente en el informe, con la referencia del pilar de seguridad del marco de buenas prácticas del proveedor (Amazon Web Services, 2024).

10. Requisitos preliminares y criterios de aceptación

Se relacionan los requisitos preliminares de mayor valor, trazados hacia el control o el objetivo que los origina. El detalle completo corresponde a la fase de ajuste avanzado.

La Tabla 13 relaciona cada requisito con su origen, su prioridad y su criterio de aceptación.

Tabla 13

Requisitos preliminares con origen, prioridad y criterio de aceptación

ID	Tipo	Requisito preliminar	Origen	Prioridad	Criterio de aceptación
REQ-01	F	El programa deberá ejecutar el catálogo completo de controles en una sola invocación, sin intervención manual.	OE-3	Alta	Dada una invocación del programa, cuando termina, entonces existe un resultado registrado para cada uno de los ocho controles del catálogo.
REQ-02	F	El programa deberá conservar, por cada prueba, el comando o petición ejecutada, su salida literal y la marca de tiempo.	Causa directa 2	Alta	Dado un papel de trabajo, cuando se consulta, entonces contiene el procedimiento exacto, la salida sin editar y la fecha y hora de ejecución.
REQ-03	F	El programa deberá calcular y almacenar la huella criptográfica del archivo de evidencia de cada prueba.	Causa directa 2 / OE-3	Alta	Dado un archivo de evidencia, cuando se recalcula su huella, entonces coincide con la almacenada en el índice; y si el archivo se modifica, entonces deja de coincidir.
REQ-04	F	El programa deberá comparar el resultado obtenido contra el criterio definido y clasificar cada control como conforme o desviado.	OE-2	Alta	Dado un control con criterio definido, cuando se ejecuta su prueba, entonces el resultado queda clasificado y la clasificación no depende de interpretación posterior.
REQ-05	F	El programa deberá ejecutar pruebas sustantivas autenticándose con usuarios de prueba de distintos roles y organizaciones.	C-05 / C-06 / C-07	Alta	Dado un usuario de prueba del rol conductor, cuando el programa invoca una operación de administración, entonces registra el código de respuesta obtenido y el registro producido en la bitácora del sistema auditado.
REQ-06	F	El programa deberá verificar la integridad de la bitácora recalculando su cadena de funciones hash.	C-08	Alta	Dada una bitácora íntegra, cuando se ejecuta el verificador, entonces informa cadena válida; y tras una alteración controlada de un

ID	Tipo	Requisito preliminar	Origen	Prioridad	Criterio de aceptación
					registro, entonces informa el punto de ruptura.
REQ-07	NF	Integridad. El almacén de papeles de trabajo deberá impedir la modificación silenciosa de la evidencia almacenada.	OE-3	Alta	Dado un archivo de evidencia, cuando se sobrescribe, entonces la versión anterior sigue siendo recuperable y la huella almacenada deja de coincidir con el contenido actual.
REQ-08	NF	Reproducibilidad. Un tercero deberá poder reejecutar el programa y obtener el mismo resultado para cada control.	Efecto 2 / OE-4	Alta	Dada una cuenta con el sistema auditado sin cambios, cuando un evaluador distinto ejecuta el programa, entonces obtiene la misma clasificación para los ocho controles.
REQ-09	NF	Trazabilidad. Cada hallazgo del informe deberá remitir al papel de trabajo que lo sustenta.	OE-4 / ISACA (2020)	Alta	Dado un hallazgo del informe, cuando se sigue su referencia, entonces se llega al papel de trabajo con la evidencia y la huella que lo respaldan.

Nota. F corresponde a requisito funcional y NF a requisito no funcional. Los criterios se expresan en la forma dado-cuando-entonces para que puedan convertirse directamente en casos de prueba del propio programa.

11. Metodología y plan inicial de trabajo

El proyecto adopta la secuencia de un trabajo de aseguramiento conforme al marco de prácticas profesionales de auditoría de sistemas (ISACA, 2020): planeación y definición del universo auditable, relevamiento y diseño del programa de pruebas, ejecución y obtención de evidencia, y evaluación y comunicación de resultados. Sobre esa secuencia se superpone un ciclo incremental de construcción, porque el ejecutor se desarrolla en paralelo con el sistema que va a auditar y solo puede probar controles ya implementados. Las técnicas empleadas son la revisión documental de marcos de referencia para derivar el catálogo, la inspección de configuración mediante la interfaz de programación del proveedor, la reejecución de operaciones con usuarios de prueba, y el recálculo criptográfico para la verificación de integridad.

La Tabla 14 presenta las fases del plan con sus actividades, responsables e hitos de cierre.

Tabla 14

Fases, actividades, responsables e hitos del plan de trabajo

Fase	Actividades principales	Responsable	Semanas	Hito de cierre
F1. Planeación	Definición del universo auditable; derivación del catálogo de controles desde los marcos de referencia; asignación de la rotación interna de independencia.	Oscar Julián Rincón (líder)	1 a 3	Matriz de controles aprobada por el equipo.
F2. Diseño del programa	Definición del procedimiento, el criterio y la evidencia esperada de cada prueba; diseño del almacén de papeles de trabajo.	Sergio Alejandro Montoya (líder)	4 a 5	Programa de auditoría documentado.
F3. Construcción	Desarrollo del ejecutor; implementación del cálculo de huellas y del almacén; creación de los usuarios de prueba por rol y organización.	Nicolás Torres (líder)	6 a 9	Ejecutor operativo sobre el catálogo completo.
F4. Ejecución y comunicación	Ejecución del catálogo; evaluación de desviaciones; reejecución por un integrante distinto; redacción del informe de hallazgos.	Oscar Julián Rincón (líder)	10 a 12	Informe de auditoría entregado con sus papeles de trabajo.

Nota. La regla de independencia interna condiciona la asignación: quien construyó un componente de Rastro no ejecuta ni evalúa las pruebas de ese componente, y la reejecución de la fase 4 la realiza un integrante distinto de quien desarrolló el ejecutor. La duración en semanas corresponde a la planeación del equipo y se ajustará al calendario definitivo de la asignatura.

La gestión de versiones se realiza en un repositorio con control de versiones distribuido, donde se versionan la matriz de controles, el programa de pruebas, el código del ejecutor y la secuencia de despliegue. Los papeles de trabajo no se versionan allí: se conservan en el almacén descrito en el apartado 9.3, porque su valor depende de que permanezcan sin edición y de que su huella coincida. El informe final referencia cada papel de trabajo por su identificador y su huella.

Declaración de uso de herramientas de inteligencia artificial. El equipo utilizó Claude, un asistente conversacional basado en modelos de lenguaje de gran escala (Anthropic, 2026), como apoyo en la redacción y la estructuración de este documento y en la elaboración de las figuras. La definición del universo auditable, la derivación del catálogo de controles, la ejecución de las

pruebas y la evaluación de los hallazgos corresponden a los integrantes del equipo, que asumen la responsabilidad sobre la exactitud del contenido y sobre la verificación de las fuentes citadas.

12. Viabilidad preliminar

12.1 Viabilidad técnica

Los recursos disponibles son las capacidades relacionadas en la Tabla 3, el rol de ejecución preexistente del laboratorio y el acceso completo al sistema auditado. La prueba preliminar de la Tabla 4 confirmó que el equipo puede consultar la configuración de un recurso y contrastar su comportamiento efectivo, que son las dos operaciones sobre las que se construye todo el programa. Las brechas son dos. La primera es que el sistema auditado se desarrolla en paralelo, de modo que las pruebas sustantivas no pueden construirse antes de que existan los controles que van a ejercitar; se atiende sincronizando la fase 3 de este proyecto con el avance de Rastro y priorizando las pruebas de cumplimiento, que no dependen de la aplicación. La segunda es que la retención inmutable del almacén de evidencia puede no estar habilitada en el laboratorio, en cuyo caso el control se sustituye por versionado más huella criptográfica y la diferencia se documenta.

Decisión: viable con condiciones. La condición es la confirmación del supuesto SU-01 durante la primera fase.

12.2 Viabilidad operativa

El programa no introduce cambios en la operación de un tercero: sus usuarios son los propios integrantes en su papel de auditores. Lo que sí exige es disciplina de procedimiento, porque una auditoría pierde su valor si la evidencia se recoge de forma desordenada o si se completa una prueba que no se ejecutó. Esa disciplina se sostiene con dos medidas: el programa registra

automáticamente lo que hizo, sin depender de que alguien lo anote, y la reejecución por un integrante distinto detecta cualquier resultado que no se reproduzca.

La brecha operativa relevante es la independencia: el equipo audita su propio trabajo y ninguna medida interna elimina por completo esa limitación. **Decisión: viable con condiciones.** Las condiciones son aplicar la rotación interna descrita en el apartado 11 y declarar la limitación de independencia en el informe final.

12.3 Viabilidad económica y temporal

El programa se ejecuta por demanda y su consumo es marginal frente al del sistema auditado: unas pocas invocaciones de cómputo, consultas de configuración en modo lectura y el almacenamiento de archivos de evidencia de tamaño reducido. No incorpora ningún componente con cargo fijo adicional, porque reutiliza la llave de cifrado y el contenedor ya existentes en la cuenta. El riesgo presupuestal del proyecto no proviene de este programa sino del sistema auditado, y está tratado en su propio documento.

En lo temporal, el proyecto dispone de doce semanas y una capacidad estimada de ocho horas semanales por integrante. El cronograma asigna cuatro semanas a la construcción del ejecutor, que es la fase de mayor incertidumbre por su dependencia del avance del sistema auditado. **Decisión: viable con condiciones.** Las condiciones son mantener la ejecución por demanda en lugar de programada, y cuantificar el consumo con la calculadora oficial de precios antes de almacenar volúmenes de evidencia mayores a los previstos. El equipo no reporta cifras que no haya verificado.

12.4 Viabilidad legal, ética y de seguridad

En lo legal, la evidencia recogida no contiene datos personales porque el sistema auditado opera con datos sintéticos, de modo que el proyecto no genera obligaciones bajo la Ley 1581 de 2012. En seguridad, el programa introduce un riesgo propio que conviene enunciar: el almacén de papeles de trabajo concentra información sobre las debilidades del sistema auditado, y su divulgación facilitaría un ataque. El control es restringir la lectura del almacén al rol auditor y limitar la circulación del informe a los destinatarios del apartado 3.1. Un segundo riesgo es que el programa, al ejecutarse con el rol compartido del laboratorio, dispone de permisos de escritura que un auditor no debería tener; el equipo lo declara como hallazgo permanente y no como una condición aceptable de diseño.

En lo ético, la amenaza de autorrevisión descrita en el apartado 3.3 es la limitación central del trabajo. El equipo la atiende con rotación interna, determinismo del programa y reejecución independiente, y la declara de forma expresa en el informe. Un principio adicional gobierna la ejecución: ninguna prueba se reporta como realizada si no se ejecutó, y ningún resultado se ajusta para que un control aparezca como conforme. **Decisión: viable con condiciones.** Las condiciones son mantener la restricción de acceso al almacén de papeles de trabajo y declarar la limitación de independencia en el informe final.

13. Riesgos iniciales

La Tabla 15 prioriza los riesgos identificados con su respuesta y su responsable.

Tabla 15

Matriz de riesgos iniciales del proyecto

ID	Causa y evento	Consecuencia	Prob.	Impacto	Respuesta	Responsable
R-01	El sistema auditado no implementa a tiempo los	Las pruebas sustantivas y de integridad no	Alta	Alto	Mitigar: sincronizar la fase 3 con el avance del sistema auditado y	Nicolás Torres

ID	Causa y evento	Consecuencia	Prob.	Impacto	Respuesta	Responsable
	controles de acceso o la bitácora.	pueden ejecutarse y el alcance se reduce a cumplimiento.			priorizar las pruebas que no dependen de la aplicación. Si persiste, documentar la limitación de alcance en el informe.	
R-02	Un defecto del propio ejecutor clasifica como conforme un control que no lo está.	La auditoría emite una conclusión falsa, que es el peor resultado posible de un trabajo de aseguramiento.	Media	Muy alto	Mitigar: cada prueba se valida en dos sentidos, comprobando que detecta la desviación cuando esta se introduce deliberadamente y no solo que informa conformidad.	Oscar Rincón
R-03	La amenaza de autorrevisión sesga la evaluación de un control diseñado por el propio evaluador.	Un hallazgo real se clasifica como aceptable.	Media	Alto	Mitigar y declarar: rotación interna de responsabilidades, criterio tomado de marcos externos y no del equipo, y declaración expresa de la limitación en el informe.	Equipo
R-04	El catálogo omite un control relevante porque nadie lo programó.	El informe transmite una cobertura mayor que la real.	Media	Medio	Mitigar: derivar el catálogo de marcos de referencia y declarar explícitamente en el informe qué quedó fuera del alcance y por qué.	Oscar Rincón
R-05	La expiración de credenciales interrumpe una ejecución a la mitad.	Papeles de trabajo incompletos que podrían interpretarse como pruebas fallidas.	Alta	Bajo	Mitigar: el ejecutor registra el estado de cada prueba y marca la ejecución como incompleta, de modo que un resultado ausente nunca se confunda con una desviación.	Nicolás Torres
R-06	Se pierde el acceso a la cuenta del laboratorio y con él la evidencia almacenada.	Los papeles de trabajo dejan de ser recuperables y los hallazgos pierden sustento.	Media	Alto	Mitigar: exportar periódicamente el índice y los archivos de evidencia con sus huellas, de modo que la reejecución en una cuenta nueva pueda contrastarse con lo obtenido antes.	Sergio Montoya

Nota. La probabilidad y el impacto se valoran de forma cualitativa. R-02 concentra la atención porque su materialización invalidaría la conclusión del trabajo, no solo una prueba.

14. Resultados, entregables e indicadores esperados

Cada resultado se asocia a un objetivo específico y a una forma de comprobación. Los indicadores se refieren a propiedades del programa y de la evidencia producida, y no a mejoras en la seguridad del sistema auditado, porque el proyecto verifica controles y no los corrige.

La Tabla 16 asocia cada entregable con su indicador, su meta y su fuente de verificación.

Tabla 16

Entregables, indicadores y fuentes de verificación

OE	Entregable	Indicador	Meta	Fuente de verificación
OE-1	Matriz de controles trazada a marcos de referencia.	Controles del catálogo con referencia normativa explícita.	Ocho de ocho	Revisión de la matriz contra los marcos citados en el apartado 4.
OE-2	Programa de auditoría con procedimiento y criterio por prueba.	Pruebas con resultado esperado definido antes de ejecutarse.	Todas	Documento de diseño versionado, con fecha anterior a la primera ejecución.
OE-3	Ejecutor automatizado y almacén de papeles de trabajo.	Controles ejecutados en una sola invocación, cada uno con comando, salida, fecha y huella.	Ocho de ocho	Índice de papeles de trabajo y archivos de evidencia de una ejecución completa.
OE-3	Verificación de la integridad del almacén.	Detección de la modificación de un archivo de evidencia por discordancia de su huella.	Detectada	Huella recalculada antes y después de una modificación controlada.
OE-4	Validación en doble sentido de cada prueba.	Pruebas que detectan la desviación cuando esta se introduce deliberadamente.	Ocho de ocho	Registro de la ejecución sobre una configuración alterada a propósito y su resultado.
OE-4	Reejecución independiente.	Controles cuya clasificación se reproduce al ser ejecutados por un integrante distinto.	Ocho de ocho	Comparación de los dos índices de papeles de trabajo y de sus huellas.
OE-4	Informe de auditoría.	Hallazgos que enuncian condición, criterio, causa y efecto y remiten a su papel de trabajo.	Todos	Informe final y trazabilidad de cada referencia.

Nota. El quinto indicador es el más exigente y el más importante: comprobar que una prueba informa conformidad no demuestra que sirva; demostrarlo requiere verificar que detecta la desviación cuando esta existe.

Referencias

Amazon Web Services. (2024). AWS Well-Architected Framework: Security pillar.

<https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html>

Anthropic. (2026). Claude (versión Opus 5) [Modelo de lenguaje de gran escala].

<https://claude.ai>

Center for Internet Security. (s. f.). CIS Amazon Web Services Foundations Benchmark.

https://www.cisecurity.org/benchmark/amazon_web_services

Chan, D. Y., & Vasarhelyi, M. A. (2011). Innovation and practice of continuous auditing.

International Journal of Accounting Information Systems, 12(2), 152-160.

<https://doi.org/10.1016/j.accinf.2011.01.001>

Congreso de la República de Colombia. (2012, 17 de octubre). Ley 1581 de 2012. Por la cual se dictan disposiciones generales para la protección de datos personales. Diario Oficial No. 48.587.

International Organization for Standardization. (2022). ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements.

ISACA. (2018). COBIT 2019 framework: Governance and management objectives. ISACA.

ISACA. (2020). ITAF: A professional practices framework for IS audit/assurance (4.^a ed.).

ISACA.

ISACA. (s. f.). Code of professional ethics. <https://www.isaca.org/credentialing/code-of-professional-ethics>

Kent, K., & Souppaya, M. (2006). Guide to computer security log management (NIST Special Publication 800-92). National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-92>

OWASP Foundation. (2021). OWASP Top 10:2021 — A01:2021 Broken access control.

https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Schneier, B., & Kelsey, J. (1999). Secure audit logs to support computer forensics. *ACM Transactions on Information and System Security*, 2(2), 159-176.

<https://doi.org/10.1145/317087.317089>

Vasarhelyi, M. A., & Halper, F. B. (1991). The continuous audit of online systems. *Auditing: A Journal of Practice & Theory*, 10(1), 110-125.

Anexo. Matriz de retroalimentación docente

Espacio reservado para el registro de hallazgos por parte del docente. El equipo conservará el mismo identificador en la entrega de ajuste avanzado y aportará evidencia de cada corrección.

La Tabla 17 queda reservada para el registro de hallazgos por parte del docente.

Tabla 17

Registro de retroalimentación y seguimiento de correcciones

ID	Criterio	Hallazgo	Acción requerida	Evidencia esperada	Estado
OBS-01					Pendiente
OBS-02					Pendiente
OBS-03					Pendiente
OBS-04					Pendiente
OBS-05					Pendiente
OBS-06					Pendiente
OBS-07					Pendiente
OBS-08					Pendiente